实验 L14：四层护栏攻防（SQL 攻防 / PII 脱敏 / Secret 管理）

（实验指导 | 对应学习情境 L14 | 企业站 2 学时 | 实验⑭）

项	内容
实验类型	设计性 + 攻防实验
实验环境	课程环境 sqlguard 服务（隔离靶场）
分组	结对（攻方/守方互换）
提交物	攻防记录 PR（每个攻击样本注明被第几层拦截）+ PII 词边界权衡案例

一、实验目标

1. 【应用】构造 5 类攻击样本，验证四层护栏（语法 AST 白名单 / 强制 LIMIT / 租户表授权 / 审批工作流）的拦截点。
2. 【评价】用真实案例讨论 PII 启发式脱敏的"误杀/漏杀"权衡（宁漏勿误的工程取舍）。
3. 【应用】按 SCS 铁律完成一次 Secret 正确注入 vs 一次错误演示（写入代码的对照）。

二、环境与准备

- **靶场纪律**：所有攻击只允许对 sqlguard 靶场发起；对任何真实服务/数据库攻击 = 安全红线，直接驳回并上报。
- 攻击样本一律以 `attack/` 目录隔离存放并显式标注，**不得伪装成正常代码提交**（本课程要求透明攻防，不要求渗透伪装）。

三、实验步骤

步骤 1：攻击样本构造与拦截验证（60′）

#	攻击样本	预期拦截层	实际拦截层	拦截依据
1	`DROP TABLE dwd_order`	①AST 白名单		
2	`SELECT * FROM dim_store`（无 LIMIT 大表）	②强制 LIMIT		
3	越权查询他租户表	③租户授权		
4	`SELECT ... INTO OUTFILE '/tmp/x'`	①AST 白名单		
5	多语句注入 `; DELETE FROM ...`	①AST 白名单		

✓ 验证点：5 个样本全部记录"实际拦截层"与报错原文截图；有未被拦截的样本立即上报教师（这是最有价值的发现）。

步骤 2：PII 脱敏词边界实验（30′）

用教师发放的脱敏模块，测试三类数据：

样本	期望	实际	词边界问题
`mobile` 列值 13800000000	脱敏		
`order_no` 含 11 位数字（订单号）	不脱敏（误杀候选）		
备注列中夹带手机号	脱敏		

讨论题（写入报告）：为什么本项目选择"**meta 标记优先 + 列名启发式兜底**"而不是"内容正则全扫"？漏配一列和误杀一列，哪个的业务代价更大？

步骤 3：Secret 管理对照（10′）

1. 错误演示（不入库，仅本地演示）：把 token 写进 yaml → `git secrets`/扫描工具报警。
2. 正确做法：K8S Secret + 环境变量注入。
3. 复习生产约定：`x-internal-token` 一类内部凭据只经 Secret 分发。

四、常见坑与排障

现象	原因与处置
样本 2 未被 LIMIT 拦截	LIMIT 层只对无 LIMIT 语句生效；确认样本是否带了 LIMIT
把"未拦截"当成实验失败	未拦截=护栏缺口=最高价值发现，如实记录上报
攻击样本混进正常目录	违反透明攻防纪律；移入 attack/ 并在 PR 描述说明

五、提交物与验收标准

提交物	验收标准
攻防记录	5 样本拦截层判定 + 截图；未拦截项上报记录
PII 报告	三样本实验 + 权衡讨论（引用 L14 讲义取舍框架）
Secret 对照	错误演示报警截图 + 正确做法清单

六、诚实清单（提交前必填）

未验证/未完成事项	原因	计划补救